Fakultät
Angewandte Informatik



FALLBEISPIEL

ISMS Richtlinien

ChemoDemo AG

Fantasiestr. 1

4711 München

im Folgenden kurz ChemDemo genannt

Dok.nr.: ISMS-0004
Datum: 1.10.2021
Autor: OT-CISO, IT-CISO
Status: gültig

Technische Hochschule Deggendorf
Dieter-Görlitz-Platz 1
94469 Deggendorf

Tel.: +49 991 3615-131

www.th-deg.de
info@th-deg.de

1. Inhalt

1. Inhalt 1
2. Richtlinien 1
3. Kontinuierlicher Verbesserungsprozess (KVP) 1
4. Asset Management 2
5. Klassifizierung von Informationen 2
6. Change Management 4
7. Vorfälle der Informationssicherheit (Security Incident Management) 4
8. Management von Zulieferern (Third Party Management) 5
9. Physische Sicherheit 5
10. Passwortrichtlinie 6
11. Verwendung von mobilen Geräten/Speichermedien 6
12. Referenzen 7

2. Richtlinien

Die ChemoDemo AG (im Folgende kurz als ChemoDemo bezeichnet) hat eine Leitlinie zur Informationssicherheit für alle Bereiche der IT und OT erlassen (siehe [CD-ISMS-0001-Leitlinie]). Zudem sind weitere Richtlinien bzgl. Informationssicherheit eingeführt, die in diesem Dokument beschrieben werden.

Der Geltungsbereich für das ISMS ist definiert in [CD- ISMS-0003-Übersicht].

Die gesamte ISMS Dokumentation ist regelmäßig einem Review zu unterziehen.

3. Kontinuierlicher Verbesserungsprozess (KVP)

ChemoDemo hat einen kontinuierlichen Verbesserungsprozess für die IT / OT mit folgenden Elementen etabliert:

- Jährliche Audits bzgl. Informationssicherheit nach einem Auditprogramm, das für 3 Jahre entwickelt wird. Alle Themen der Informationssicherheit nach ISO 27001/IEC 62443-2-1 werden innerhalb von 3 Jahren wenigstens einmal auditiert und bewertet.
- Jährliche wird ein Management Review durchgeführt

Mit diesen Elementen ist folgender kontinuierlicher Verbesserungsprozess umgesetzt:

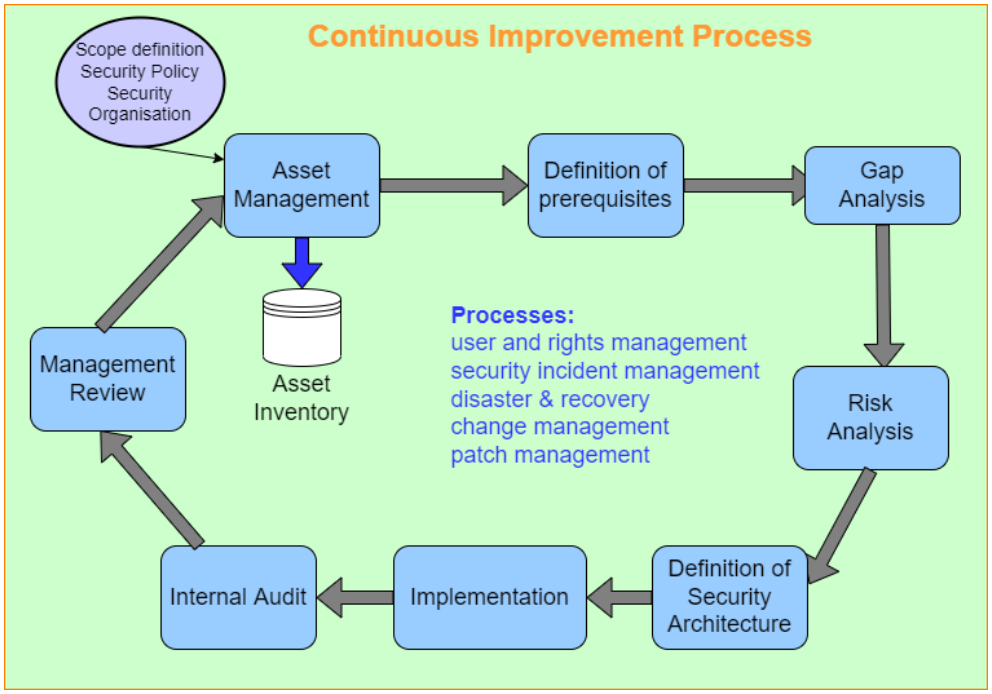


Abbildung 1: Kontinuierlicher Verbesserungsprozess für ChemoDemo bzgl. Informaitonssicherheit

Nachfolgende werden wesentlichen Elemente des KVP behandelt und stellen Richtlinien für ChemoDemo dar.

4. Asset Management

Alle Assets im Geltungsbereich / Scope werden erfasst und mit geeigneten Attributen beschrieben.

Das Asset Management wird bei jeder Änderung über das Change Management darüber informiert, welche Assets, Attribute etc. geändert, neu aufgenommen oder gelöscht werden müssen. Diese Informationen werden im Assset Inventory aufgenommen und führe zu einer neuen Version des Asset Inventories. Veraltete Versionen von Asset Inventories werden nicht gelöscht, sondern 3 Jahre archiviert.

5. Klassifizierung von Informationen

Informationen sind gemäß den Schutzzielen Vertraulichkeit, Integrität und Verfügbarkeit zu klassifizieren. Folgende Schutzbedarfsklassen gelten:

Klasse	Erläuterung	
katastrophal	Vertraulichkeit	Sehr geheime Daten: Diese sind nur einem sehr eingeschränkten Benutzerkreis zugänglich oder werden vom Kunden als besonders vertrauenswürdig eingestuft (z.B. Rezepturen, Konstruktionspläne, Daten der Finanzabteilung etc.).
	Integrität	Nur ein sehr eingeschränkter Personenkreis darf die Änderung dieser Daten veranlassen oder durchführen.

	Verfügbarkeit	Die maximale Wiederanlaufzeit darf **1 Stunde** nicht überschreiten. Die definierte max. kumulierte Ausfallzeit innerhalb eines Quartals darf **2 Stunden / Quartal** nicht überschreiten
	mögliche Folgen eines Verstoßes / einer Verletzung: sehr hohe finanzielle Verluste bis hin zur existentieller Bedrohung des Geschäftes von ChemoDemo, Vertrauensverlust in einer sehr breiten Öffentlichkeit Sehr schwere Verstöße gegen Gesetze wie z.B. Datenschutz etc., Verträge	

Klasse	**Erläuterung**	
hoch	Vertraulichkeit	Geheime Daten: diese sind nur einem eingeschränkten Benutzerkreis zugänglich oder werden vom Kunden als vertrauenswürdig eingestuft (z.B. kumulierte Verbrauchsdaten, Konfigurationsdaten, Prozessdaten).
	Integrität	Nur ein eingeschränkter Personenkreis darf die Änderung der Daten veranlassen oder durchführen.
	Verfügbarkeit	Die maximale Wiederanlaufzeit darf **2 Stunden** nicht überschreiten. Die definierte max. kumulierte Ausfallzeit innerhalb eines Quartals darf **4 Stunden / Quartal** nicht überschreiten
	mögliche Folgen eines Verstoßes: hohe finanzielle Verluste, die unter Kontrolle/Verantwortung des Top Management stehen, die in der Bilanz einen deutlichen Niederschlag haben. Eine existentielle Bedrohung des Unternehmens ist nicht absehbar. Vertrauensverlust in einer breiten Öffentlichkeit (z.B. regional, nur in einem Land) Verstöße gegen Gesetze wie z.B. Datenschutz etc., Verträge	

Klasse	**Erläuterung**	
Niedrig bis mittel	Vertraulichkeit	die Daten sind einem breiteren internen Personenkreis zugänglich, aber nicht öffentlich
	Integrität	Ein breiterer interner Personenkreis darf die Änderung der Daten veranlassen oder durchführen.
	Verfügbarkeit	Die maximale Wiederanlaufzeit darf **24 Stunden** nicht überschreiten. Die definierte max. kumulierte Ausfallzeit innerhalb eines Quartals darf **48 Stunden / Quartal** nicht überschreiten

	mögliche Folgen eines Verstoßes: führt nur zu geringen finanziellen Verlusten, werden vom mittleren Management verantwortet. führt zu einem Vertrauensverlust in einer eingeschränkten Öffentlichkeit Stellt keine wesentlichen Verletzungen von Gesetzen und/oder Verträge dar.

6. Change Management

Folgende Change-Kategorien sind definiert:

Minor Change

Minor Changes beinhalten keine oder nur unwesentliche Risiken und haben keine Auswirkung auf die Safety. Minor Changes können daher ohne einen Change Request durchgeführt werden, ein Fallback ist von vornherein klar und ist einfach durchführbar. Minor Changes entsprechen wiederkehrenden Standardaufgaben und machen Änderungen im Asset Inventory nicht notwendig. Minor Changes sind aber zu beschreiben und einmal im Jahr durch Verantwortliche auf der Ebene Abteilung frei zu geben.

Emergency-Change

Emergency Changes werden nur in einem Notfall ausgeführt Emergency Changes durch eine Business Impact Analyse identifiziert und beschrieben. Für die Notfälle sind Notfallpläne zu erarbeiten, die dann in einem Emergency Change ausgeführt werden können. Zudem sind Mitarbeiter zur Durchführung von Emergency Changes zu autorisieren.
Emergency Changes müssen nach der Durchführung zeitnah protokolliert werden.

Normal Change

Hierfür ist ein Change Request notwendig.
Normal Changes sind alle Änderungen, die nicht unter die Kategorien Minor oder Emergeny Changes fallen.

7. Vorfälle der Informationssicherheit (Security Incident Management)

Um Vorfälle dem BSI[1] melden zu können, sind folgende Kategorien für Vorfälle der Informationssicherheit definiert:

Rot: ein Ausfall der kritischen Versorgungsdienstleistung auf lokaler, regionaler, nationaler Ebene wird erwartet bzw. ist eingetreten

Orange: eine Beeinträchtigung der kritischen Versorgungsdienstleistung bis hin zum Notbetrieb wird erwartet bzw. ist eingetreten

☐

Gelb: Verstärkte Auffälligkeiten in der Kritischen Informationsinfrastruktur, aber keine Beeinträchtigung der Versorgungsdienstleistung

[1] Bundesamt für Sicherheit in der Informationstechnik

Der Security Incident Management Prozess umfasst folgende Phasen: Detektion einer Störung, Ticket bzgl. der Störung im Ticketsystem eröffnen, Bewertung der Störung als Security Incident (wenn kein Security Incident vorliegt, ist mit dem Prozess allgemein für Störungen fortzuführen), Behebung des Security Incidents (unter Umständen auch nur mit einem Work Around), Schließen des Tickets, Lessons Learned.

8. Management von Zulieferern (Third Party Management)

Ein Zulieferer muss folgenden Qualitätskriterien genügen

1. Der Zulieferer muss die Qualifikation für die Aufgaben besitzen, für die er vorgesehen ist.
2. Mitarbeiter des Zulieferers sind für die von ihnen ausgeführten Aufgaben qualifiziert (Zertifikate, Berufserfahrungen)
3. Mitarbeiter sich bzgl. Informationssicherheit geschult
4. Der Zulieferer wird als zuverlässig eingeschätzt: wirtschaftliche Stabilität, zuverlässiger Geschäftspartner

Für die Überprüfung der oben genannten Qualitätskriterien eines Zulieferers ist ein Prozess im Vorfeld zu etablieren. Durch diesen Prozess werden die Zulieferer auf Basis eines Kriterienkatalogs von Verantwortlichen aus relevanten Fachabteilungen von ChemoDemo bewertet. Die durchgeführte Qualitätsprüfung wird dokumentiert und vom Management genehmigt. Die Qualitätsprüfung muss für alle Zulieferer regelmäßig wiederholt werden.
Weiter ist ein Prozess zu etablieren, der gewährleistet, dass Zulieferer, die sich als nicht zuverlässig oder kompetent erweisen, aus der Liste geeigneter Zulieferer gestrichen werden. Die Löschung eines Zulieferers aus der Liste geeigneter Zulieferer ist unter Angabe der Gründe vom Management zu bestätigen.

9. Physische Sicherheit

Die physische Sicherheit ist ein Teil des Defense-in-Depth Ansatzes bzgl. Security von ChemoDemo. Physische Sicherheit wird durch einen mehrstufigen Zutrittsschutz zu Werksgeländen, Produktionsanlagen, Gebäuden oder Räumen der ChemoDemo realisiert. Auch hier gilt das Need-to-Know Prinzip: Zutritt wird nur gewährt, wenn dieser zur Ausübung der Aufgaben eines Mitarbeiters notwendig ist.
Alle Werksgelände sind durch einen Zaun geschützt und mit einer Kameraüberwachung ausgerüstet.
Ein Werksschutz ist an allen Standorten und Anlagen vor Ort für die Umsetzung der physikalischen Sicherheitsmaßnahmen verantwortlich. Insbesondere obliegt ihm die Kontrolle des Zutritts zu den Werksgeländen. Der Werkschutz ist in die Sicherheitsorganisation von ChemoDemo eingebunden.

Folgende Grundsätze gelten

- IT oder OT Equipment ist grundsätzlich in abschließbaren Räumen untergebracht.
- IT und OT Equipment im Gelände/im Feld, das physisch nicht abgesichert werden kann, muss durch alternative Maßnahmen (etwa Monitoring, Kameraüberwachung etc.) abgesichert werden.
- Auf Basis einer Risikoanalyse ist ein geeignetes physisches Zonenkonzept mit entsprechenden physischen Schutzmaßnahmen für jeden Standort zu erarbeiten und umzusetzen. Insbesondere sind Bereiche mit sehr hohem physikalischen Schutzbedarf zu identifizieren. Für diese Bereiche sind spezielle Zutrittssicherungen umzusetzen (Beispiel: erst nach 2-Faktor-Authentisierung

kann ein Raum mit sehr hohem Schutzbedarf betreten werden; z.B. der Raum in dem PLCs untergebracht sind).

10. Passwortrichtlinie

Wo immer möglich, sind folgende Anforderungen an Passwörter technisch zu erzwingen:

- Ausreichende Güte der Passwörter:
  - Länge von mindestens 10 (10) Zeichen
  - Benutzung mindestens einer Ziffer
  - enthält mindestens einen Großbuchstaben und einen Kleinbuchstaben
  - enthält mindestens ein Sonderzeichen
- Passwörter müssen mindestens alle 90 Tage geändert werden
- Beim erstmaligen Anmelden muss das Passwort anschließen geändert werden
- Passwörter dürfen auf einer Komponente / durch eine Applikation nicht ungeschützt gespeichert werden. Passwörter sind mit Hilfe kryptographischer Verfahren zu schützen.

Können diese Anforderungen technisch nicht erzwungen werden, muss der Benutzer dafür Sorge tragen, dass die oben genannten Anforderungen eingehalten werden.

Benutzer Passwörtern haben folgende Regeln einzuhalten:

- Passwörter und andere Geheimnisse (wie private Schlüssel, PINs) müssen unbedingt geheim gehalten werden
- Passwörter dürfen grundsätzlich nicht aufgeschrieben werden
- Passwörter, die für private Zwecke genutzt werden, dürfen nicht für Geschäftszwecke benutzt werden und vice versa

11. Verwendung von mobilen Geräten/Speichermedien

Die Verwendung von privaten mobilen Geräten und Speichermedien ist grundsätzlich untersagt. Nur von ChemoDemo vorgesehene, freigegebene und für bestimmte Aufgaben vorgesehene mobile Geräte und Speichermedien dürfen eingesetzt werden. Es ist ein Prozess zu etablieren, der

- die erlaubten und notwendigen mobilen Geräte und Speichermedien identifiziert
- die mit dem Einsatz dieser mobilen Geräte und Speichermedien verbunden Risiken bewertet und als akzeptabel ausweist. Falls das Risiko als nicht akzeptabel bewertet wird, dürfen mobile Geräte und Speichermedien nicht eingesetzt werden.
- gewährleistet, dass für die freigegebenen Geräte und Speichermedien besondere Sicherheitsmaßnahmen umgesetzt werden, z.B. Verschlüsselung, Virencheck vor jedem und nach jedem Gebrauch etc.
- gewährleistet, dass jederzeit nachvollziehbar ist, wer welche Geräte und Speichermedien für welchen Zweck eingesetzt hat
- gewährleistet, dass Geräte und Speichermedien nach Gebrauch für unautorisierte Dritte nicht zugänglich sind (z.B. sind die Geräte in einem verschließbaren Schrank in einem abgeschlossenen Raum untergebracht werden)

12. Referenzen

Siehe [CD-0002-interneReferenzen]